

Análisis de Riesgos

Grupo 3

David Jiménez Ruiz
Abel García Domínguez
Jose María Escalón Prada



Contenido

01 Contexto y Activos

02 Valoración de Activos

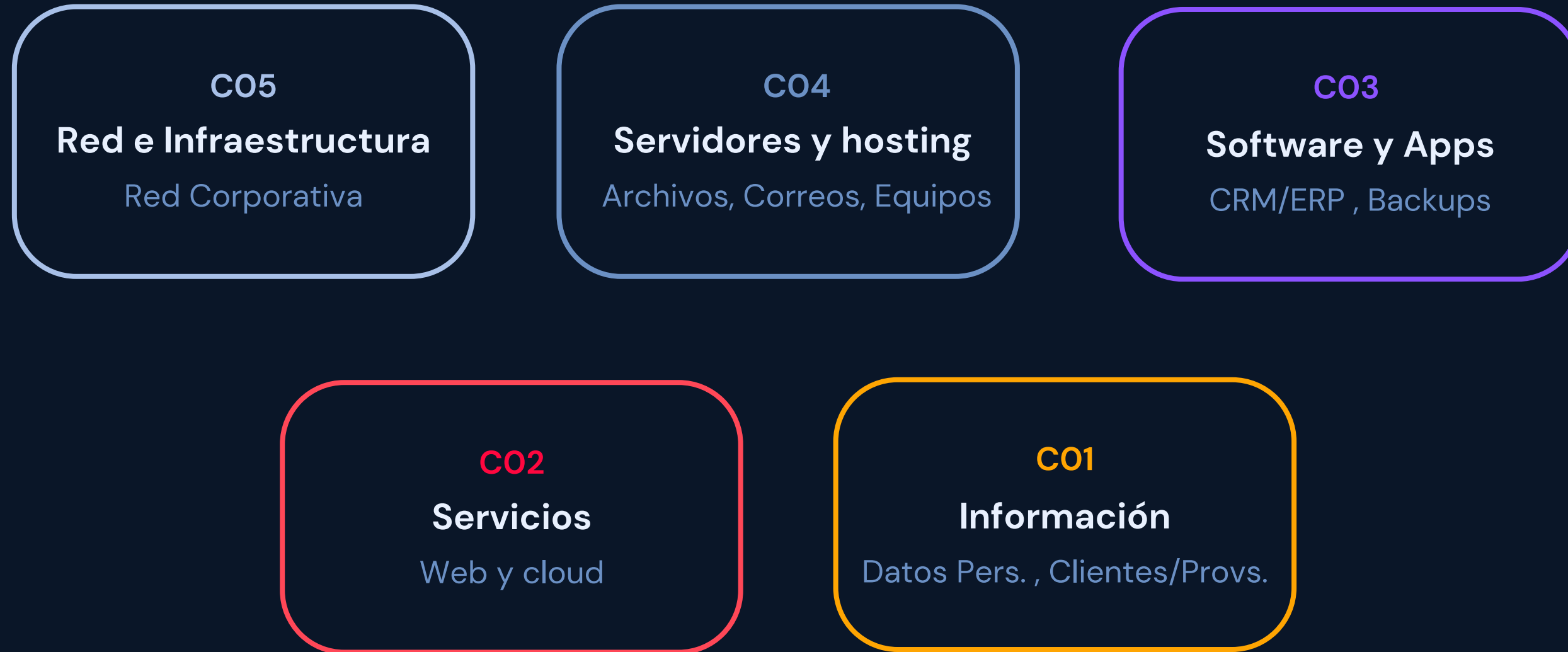
03 Riesgo Acumulado

04 Riesgo Repercutido

05 Buenas Prácticas

06 Plan de Acción

Activos: Capas



Todos los activos pertenecen al dominio **[base] SERV_AD**

Activos: Definición

C05

Red e Infraestructura

[ID-0006] Red Corporativa

C04

Servidores y hosting

[ID-0003] Servidor de Archivos

[ID-0004] Servidor de Correos

[ID-0005] Equipos de Usuario

C03

Software

[ID-0008] Aplicaciones CRM/ERP

[ID-0007] Sistema de Backups

C02

Servicios

[ID-0009] Página Web

C01

Información

[ID-0001] Datos Personales

[ID-0002] Información del cliente y Proveedores

Activos: Valoración

Dimensiones:

- [D] Disponibilidad,
- [I] Integridad,
- [C] Confidencialidad,
- [A] Autenticidad,
- [T] Trazabilidad

(ENS)		
NOTA	VALORACIÓN	VALOR
A+	Muy alto	9 -10
A	Alto	7-8
M	Medio	4-6
B	Bajo	1-3

Activo	D	I	C	A	T
Red Corporativa	A+	A	A	A	M
Servidor de Archivos	A	A	A	A	M
Servidor de Correos	M	M	A	M	M
Equipos de Usuario	M	B	M	M	B
CRM/ERP	A	A+	A+	A	A
Sistema de Backups	A	A	A	M	M
Página web	A	M	B	M	B
Información	A	A+	A+	A	A

Riesgo Acumulado

Sube de abajo hacia arriba. Parte de un activo de capa baja (la red, un servidor) y acumula el valor de todo lo que hay por encima que depende de él.

Amenaza	Dimensión	Impacto	Riesgo
[E.21] Errores de mantenimiento / actualización de programas (software)	C	[9]	{6,9}
[A.22] Manipulación de programas	I, C	[10]	{6,5}
[A.8] Difusión de software dañino	D, I, C	[9]	{6,3}
[A.24] Denegación de servicio	D	[A+]	{5,7}
[E.24] Caída del sistema por agotamiento de recursos	D	[A]	{5,7}
[I.6] Corte del suministro eléctrico	D	[A+]	{5,3}
[E.20] Vulnerabilidades de los programas (software)	C	[A+]	{5,3}
[X.2] Phishing	C	[A]	{5,1}
[I.10] Degradación de los soportes de almacenamiento de la información	D	[A]	{5,1}

Riesgo Acumulado

Degradación final = Degradación base (catálogo MAGERIT) × factores contextuales



Impacto = Valor del activo × Degradación de la amenaza

Riesgo = Impacto × Probabilidad

Amenaza	Dimensión	Impacto	Riesgo
[A.8] Difusión de software dañino	D, I, C	[9]	{6,3}

- 6 Riesgo calculado sobre el valor propio de un activo (lo que vale el activo)
- 3 Risgo acumulativo. Se cuenta todo lo que afecta en cascada. Puede ser menor que el inicial, si las capas superiores tienen salvaguardas que Pilar considera, o si la degradación de los activos superiores no se propaga con la misma fuerza



Riesgo Acumulado

El impacto no se puede definir, por lo que se muestra el valor del activo



Amenaza	Dimensión	Impacto	Riesgo
[E.21] Errores de mantenimiento / actualización de programas (software)	C	[9]	{6,9}
[A.22] Manipulación de programas	I, C	[10]	{6,5}
[A.8] Difusión de software dañino	D, I, C	[9]	{6,3}
[A.24] Denegación de servicio	D	[A+]	{5,7}
[E.24] Caída del sistema por agotamiento de recursos	D	[A]	{5,7}
[I.6] Corte del suministro eléctrico	D	[A+]	{5,3}
[E.20] Vulnerabilidades de los programas (software)	C	[A+]	{5,3}
[X.2] Phishing	C	[A]	{5,1}
[I.10] Degradación de los soportes de almacenamiento de la información	D	[A]	{5,1}

Riesgo Repercutido

Va de arriba hacia abajo. Parte de un activo de capa alta (los datos personales, el servicio web) y rastrea qué amenazas que ocurren por debajo le llegan hasta él. El daño baja desde el activo esencial hacia los componentes que lo sustentan.

Amenaza	Dimensión	Impacto	Riesgo
[E.21] Errores de mantenimiento / actualización de programas (software)	C	[9]	{6,9}
[A.22] Manipulación de programas	I, C	[10]	{6,5}
[A.8] Difusión de software dañino	D, I, C	[9]	{6,3}
[A.24] Denegación de servicio	D	[A+]	{5,7}
[E.24] Caída del sistema por agotamiento de recursos	D	[A]	{5,7}
[I.6] Corte del suministro eléctrico	D	[A+]	{5,3}
[E.20] Vulnerabilidades de los programas (software)	C	[A+]	{5,3}
[X.2] Phishing	C	[A]	{5,1}
[I.10] Degradación de los soportes de almacenamiento de la información	D	[A]	{5,1}

Buenas prácticas

Priorización de medias técnicas

Prioridad 1: Riesgo Crítico (R $\geq$ 6,5)

E.21: Gestión de parches

Entorno de pruebas previo a producción ,
Freeze de versiones

A.22: Control de integridad

Hash SHA-256 , Despliegue firmado , Revisión código

A.8 : EDR/Antimalware

SAST/DAST , Política software autorizado

Prioridad 2: Riesgo Alto (R 5,3–5,7)

A.24 : IDS/IPS y VLANs

Suricata/Snort , Rate limiting , Segmentación

E.24 : SIEM

Wazuh/ELK , Alertas CPU/RAM/disco $\geq$ 80%

X.2 : Formación

I.6 : Corte de suministro eléctrico

SAI/UPS en servidores críticos , Generador ante
cortes prolongados

E.20 : Vulnerabilidades de software

Análisis periódico con OpenVAS/Nessus

I.10 : Degradación de soportes

Pruebas periódicas de restauración de backup ,
Rotación de soportes , Discos cifrados

Buenas prácticas

Principios de economía circular

Objetivo: reducir residuos, extensión de la vida útil de los activos y minimizar el consumo de recursos.

Reutilización de hardware

Equipos de Usuario : valorar actualización de RAM o SSD antes de reemplazar.

Virtualización y consolidación

Servidor de Correos: consolidar más servicios en máquinas virtuales reduce consumo energético y hardware físico necesario.

Backups en disco cifrado

Sistema de Backups : los discos cifrados reutilizables tienen menor huella ambiental que soportes ópticos o cintas magnéticas de un solo uso.

Cloud como servicio (PaaS)

Servicios en la Nube : el modelo PaaS reduce infraestructura propia, optimizando el consumo de recursos compartido entre múltiples clientes.

Política de borrado seguro

Al dar de baja equipos, aplicar borrado certificado NIST 800-88 : permite reutilización o reciclaje responsable, cumpliendo también RGPD en la gestión de ID-0001 Datos Personales.

Plan de acción en ciberseguridad

Corto Plazo: 0 a 3 meses

MFA en todas las cuentas CRM/ERP

Alertas SIEM

Política de contraseñas robusta

Probar restauración de backups

Medio Plazo: 3 a 9 meses

Desplegar IDS/IPS

Análisis de vulnerabilidades con otras herramientas

VLANs: LAN, DMZ, Servidores

Formación en ciberseguridad al personal

Largo Plazo: 9 a 18 meses

Elaborar y probar Plan IR (simulacro)

Borrado seguro en equipos de baja

Auditoría externa + revisión análisis

Backup 3-2-1: copia offsite mensual

Access review trimestral CRM/ERP

Muchas gracias por su atención